● ACTIVE THREAT · CVSS 9.4 CRITICAL · CVE-2026-33634

LiteLLM PyPI Supply Chain Attack by TeamPCP

A critical supply chain compromise delivering a persistent Python backdoor to AI infrastructure environments globally â€" 95M monthly downloads at risk.

1 Executive Summary

- â€¢ TeamPCP injected a malicious backdoor into **litellm 1.82.7 and 1.82.8** on PyPI â€" a widely-used AI/LLM proxy library with **95M monthly downloads** across cloud ML and AI infrastructure.
- â€¢ The attack plants **litellm_init.pth** inside Python's site-packages directory â€" a path configuration file that silently executes arbitrary code on **every Python interpreter startup** (T1546.018) with no user interaction after initial infection.
- â€¢ Persistence is secured through a **systemd user service** (`sysmon.service`) masquerading as the legitimate Sysinternals Sysmon tool to evade analyst detection.
- â€¢ The payload establishes C2 via typosquat domains (**models.litellm.cloud**, **checkmarx.zone**) that closely mimic legitimate security vendor names to blend into normal traffic.
- â€¢ Any environment that executed `pip install litellm` between **2026-03-19 and 2026-03-24** must be treated as compromised and isolated for forensic investigation immediately.

2 CVE Details & Attack Chain

CVSS SCORE	SEVERITY	CVE ID	AFFECTED VERSIONS	VECTOR
â€"	CRITICAL	CVE-2026-33634	1.82.7 & 1.82.8	PyPI Supply Chain

DAILY DOWNLOADS

â€"

The attack targets developers and DevOps teams using LiteLLM as an AI model routing proxy. Infected environments include CI/CD pipelines, developer workstations, Kubernetes pods in ML clusters, and cloud inference services. The threat actor specifically targeted AI infrastructure due to its access to high-value API keys, cloud credentials, and model endpoints. This is the third stage of a broader TeamPCP campaign: Aqua Security Trivy (March 19) → Checkmarx GitHub Actions (March 23) → LiteLLM PyPI (March 24).

Attack Chain

STAGE 1

Supply Chain

litellm 1.82.7/1.82.8 uploaded to PyPI replacing legitimate builds

T1195.001

STAGE 2

.pth Hook

litellm_init.pth placed in site-packages, auto-executes every Python start

T1546.018

STAGE 3

Backdoor

sysmon.py installed at ~/.config/sysmon/ masquerading as Sysmon

T1036.004

STAGE 4

Persistence

sysmon.service systemd unit â€" survives reboots without root

T1543.002

STAGE 5

Exfil & C2

Credentials beaconed to models.litellm.cloud & checkmarx.zone

T1071.004

2.1 MITRE ATT&CK Techniques

TECHNIQUE ID	NAME	USAGE IN THIS CAMPAIGN
T1195.001	Supply Chain: Software Dependencies	Malicious litellm 1.82.7/1.82.8 uploaded to PyPI
T1546.018	Python Path Interception via .pth	litellm_init.pth auto-executed on every interpreter startup
T1547.016	Boot Autostart: systemd Service	sysmon.service user-level unit â€" survives reboots without root
T1036.004	Masquerading: Match Legitimate Name	sysmon.py and sysmon.service mimic Sysinternals Sysmon
T1071.004	Exfiltration Over DNS / C2	Beacon to models.litellm.cloud, checkmarx.zone
T1552	Unsecured Credentials	Harvests LLM API keys, cloud tokens, environment variables
T1059.006	Command and Scripting: Python	All backdoor execution via Python runtime
T1608.003	Stage Capabilities: Cluster Escalation	K8s privileged pod creation (node-setup-*)

3 Indicators of Compromise

TYPE	VALUE	DESCRIPTION	CONFIDENCE	SOURCE	FIRST SEEN
DOMAIN	models.litellm.cloud	TeamPCP C2 typosquat â€" NOT litellm.ai	High	ReversingLabs	2026-03-24
DOMAIN	checkmarx.zone	TeamPCP C2 â€" impersonates Checkmarx	High	Sysdig	2026-03-24
IP	45.148.10.212	TeamPCP staging infra (scan.aquasecurity.org)	High	Snyk	2026-03-19
IP	83.142.209.11	TeamPCP staging infra (checkmarx.zone)	High	Sysdig	2026-03-23
SHA256	ceNa7wMJnNHy1kRnNCcwJaFjWX3pORLfMh7xGL8TUjg	litellm_init.pth payload (34628 bytes)	High	FutureSearch	2026-03-24
FILE	litellm_init.pth	Malicious .pth hook in site-packages	High	Multiple	2026-03-24
FILE	~/.config/sysmon/sysmon.py	Persistent backdoor script	High	ReversingLabs	2026-03-24
FILE	~/.config/systemd/user/sysmon.service	Systemd persistence unit	High	Datadog	2026-03-24
FILE	/tmp/pglog, /tmp/.pg_state	Payload staging & state tracking files	Medium	Sonatype	2026-03-24
PACKAGE	litellm==1.82.7 / 1.82.8	Malicious PyPI versions	High	PyPI / Checkmarx	2026-03-24
K8S	node-setup-* (kube-system)	Privileged pod creation pattern	High	ARMO	2026-03-24
ARCHIVE	tpcp.tar.gz	TeamPCP malware archive	High	Kaspersky	2026-03-24

4 Detection Rules

10 platforms covered. Rules are consolidated â€″ related detections combined into 4â€″5 comprehensive queries per platform. Click any platform header to expand or collapse the rule code.

Sigma

YAML · SIEM-Agnostic

Consolidated Sigma rules covering the full attack chain: pip install detection, all TeamPCP file artifacts combined into one rule, C2 DNS and network connections in one rule, and a parent-child correlation for Python spawned by pip. Platform-agnostic â€" convert to any SIEM via sigma-cli or pySigma.

```
# CVE-2026-33634 — LiteLLM PyPI Supply Chain Attack (TeamPCP)
# CVSS 9.4 Critical | Platform: Sigma (Linux)
# ATT&CK: T1195.001, T1546.018, T1547.016, T1041, T1552
# Severity: Critical | Response: Isolate host, revoke pip cache, audit Python envs
# Author: Mazlum BAYDAR | Date: 2026-03-26

# ─── RULE 1: TeamPCP_Malicious_LiteLLM_Install ───
# Detects installation of backdoored LiteLLM via pip or python -m pip.
# Combines all invocation patterns (pip, pip3, python -m pip) using 1 of selection_*.
# MITRE: T1195.001 (Supply Chain Compromise — PyPI)
# Severity: critical
# Response: Block process, isolate host, purge pip cache, audit installed packages

---
title: TeamPCP - Malicious LiteLLM PyPI Package Installation
id: a1b2c3d4-1111-4444-aaaa-000000000001
status: stable
description: >
  Detects installation of backdoored LiteLLM packages (versions 1.82.7 and 1.82.8)
  distributed by TeamPCP. Covers pip, pip3, and python -m pip invocation patterns.
  These versions drop litellm_init.pth in site-packages for stealthy code execution
  on every Python interpreter startup (T1546.018).
author: Mazlum BAYDAR
date: 2026/03/26
references:
  - https://sysdig.com/blog/teampcp-pypi-supply-chain/
  - https://futuresearch.ai/blog/litellm-pypi-supply-chain-attack/
logsource:
  category: process_creation
  product: linux
detection:
  selection_pip_direct:
    Image|endswith:
      - '/pip'
      - '/pip3'
    CommandLine|contains:
      - 'litellm==1.82.7'
      - 'litellm==1.82.8'
  selection_python_m_pip:
    Image|endswith:
      - '/python'
      - '/python3'
    CommandLine|contains|all:
      - '-m pip'
      - 'install'
    CommandLine|contains:
      - 'litellm==1.82.7'
```

```
      - 'litellm==1.82.8'
  condition: 1 of selection_*
falsepositives:
  - None — versions 1.82.7 and 1.82.8 are confirmed malicious; no legitimate use
level: critical
tags:
  - attack.t1195.001
  - attack.initial_access
  - cve.2026.33634

# ─── RULE 2: TeamPCP_Artifact_Files ───
# Single consolidated file_event rule covering all TeamPCP-dropped artifacts:
# litellm_init.pth (.pth hook), sysmon.py (backdoor), sysmon.service (systemd
# persistence), /tmp/pglog (payload staging), /tmp/.pg_state (infection state).
# MITRE: T1546.018 (pth hook), T1036.005 (masquerade), T1547.016 (systemd)
# Severity: critical/high (pth+service = critical; /tmp files = medium)
# Response: Collect artifacts, kill Python processes, remove persistence units

---
title: TeamPCP - Malicious Artifact Files Created
id: a1b2c3d4-2222-4444-aaaa-000000000002
status: stable
description: >
  Single consolidated rule covering all five TeamPCP-dropped file artifacts.
  litellm_init.pth: .pth hook for code execution at Python startup (T1546.018).
  sysmon.py: persistent backdoor masquerading as Sysinternals Sysmon (T1036.005).
  sysmon.service: user-level systemd unit for reboot persistence (T1547.016).
  /tmp/pglog and /tmp/.pg_state: payload staging and infection state tracking.
author: Mazlum BAYDAR
date: 2026/03/26
references:
  - https://futuresearch.ai/blog/litellm-pypi-supply-chain-attack/
  - https://securitylabs.datadoghq.com/articles/litellm-compromised-pypi-teampcp-supply-chain-
campaign/
  - https://www.sonatype.com/blog/litellm-pypi-supply-chain
logsource:
  category: file_event
  product: linux
detection:
  selection_pth_hook:
    TargetFilename|contains: 'site-packages'
    TargetFilename|endswith: 'litellm_init.pth'
  selection_backdoor:
    TargetFilename|contains: '/.config/sysmon/'
    TargetFilename|endswith: 'sysmon.py'
  selection_persistence:
    TargetFilename|contains: '/.config/systemd/user/'
    TargetFilename|endswith: 'sysmon.service'
  selection_tmp_payloads:
    TargetFilename:
      - '/tmp/pglog'
      - '/tmp/.pg_state'
  condition: 1 of selection_*
falsepositives:
  - /tmp/pglog may appear with PostgreSQL — verify initiating process is python/pip
  - No legitimate litellm_init.pth, sysmon.py, or sysmon.service expected on Linux
```

```
  level: critical
  tags:
    - attack.t1546.018
    - attack.t1036.005
    - attack.t1547.016
    - attack.persistence
    - attack.defense_evasion
    - cve.2026.33634

  # ─── RULE 3: TeamPCP_C2_DNS_Query ───
  # DNS resolution of confirmed TeamPCP C2 domains.
  # models.litellm.cloud impersonates litellm.ai; checkmarx.zone impersonates
  # the legitimate Checkmarx security vendor. Also matches any subdomain of .litellm.cloud.
  # MITRE: T1041 (Exfiltration Over C2)
  # Severity: critical
  # Response: Block domains at DNS/firewall, capture PCAP, escalate to IR

  ---
  title: TeamPCP - DNS Query to C2 Typosquat Domains
  id: a1b2c3d4-3333-4444-aaaa-000000000003
  status: stable
  description: >
    Detects DNS resolution of confirmed TeamPCP C2 infrastructure.
    models.litellm.cloud impersonates the legitimate litellm.ai service.
    checkmarx.zone impersonates the Checkmarx security vendor.
    Any subdomain of .litellm.cloud is also flagged (wildcard actor infrastructure).
  author: Mazlum BAYDAR
  date: 2026/03/26
  references:
    - https://sysdig.com/blog/teampcp-pypi-supply-chain/
    - https://snyk.io/articles/poisoned-security-scanner-backdooring-litellm/
  logsource:
    category: dns_query
    product: linux
  detection:
    selection_c2_domains:
      QueryName|endswith:
        - '.litellm.cloud'
        - 'checkmarx.zone'
    condition: selection_c2_domains
  falsepositives:
    - None — confirmed malicious C2 domain infrastructure
  level: critical
  tags:
    - attack.t1041
    - attack.command_and_control
    - cve.2026.33634

  # ─── RULE 4: TeamPCP_C2_IP_Connection ───
  # Outbound connections to TeamPCP C2 IPs.
  # 45.148.10.212 masquerades as scan.aquasecurity.org.
  # 83.142.209.11 is the checkmarx.zone C2 endpoint.
  # MITRE: T1041 (Exfiltration Over C2)
  # Severity: critical
  # Response: Isolate host immediately, capture traffic, begin IR
```

```yaml
---
title: TeamPCP - Outbound Connection to C2 IP Infrastructure
id: a1b2c3d4-4444-4444-aaaa-000000000004
status: stable
description: >
  Detects outbound network connections to confirmed TeamPCP C2 IP addresses.
  45.148.10.212 masquerades as scan.aquasecurity.org (Trivy scanner disguise).
  83.142.209.11 is the direct IP backend for checkmarx.zone C2 domain.
  Both IPs are confirmed staging and exfiltration endpoints.
author: Mazlum BAYDAR
date: 2026/03/26
references:
  - https://snyk.io/articles/poisoned-security-scanner-backdooring-litellm/
  - https://sysdig.com/blog/teampcp-pypi-supply-chain/
logsource:
  category: network_connection
  product: linux
detection:
  selection_c2_ips:
    DestinationIp:
      - '45.148.10.212'
      - '83.142.209.11'
  condition: selection_c2_ips
falsepositives:
  - None — confirmed malicious C2 IPs with no legitimate use
level: critical
tags:
  - attack.t1041
  - attack.command_and_control
  - cve.2026.33634
```

Y **YARA** Binary & File Analysis

Three consolidated YARA rules: .pth hook file detection by content, combined backdoor and persistence rule matching sysmon.py and sysmon.service artifacts together, and malicious package metadata detection. Suitable for endpoint scanners, sandbox pipelines, and file integrity monitoring.

```
/*
 * CVE-2026-33634 — LiteLLM PyPI Supply Chain Attack (TeamPCP)
 * CVSS 9.4 Critical | Platform: YARA (file/memory scanning)
 * ATT&CK: T1195.001, T1546.018, T1547.016, T1041, T1552
 * Severity: Critical | Response: Quarantine file, isolate host, begin IR
 * Author: Mazlum BAYDAR | Date: 2026-03-26
 */

// ─── RULE 1: TeamPCP_PTH_Hook_File ───
// Detects litellm_init.pth content by matching Python execution imports
// combined with embedded C2 domain strings or TeamPCP artifact paths.
// A .pth file executing code must contain Python import statements AND
// references to the C2 infrastructure or dropped file paths.
// MITRE: T1546.018 (Python Path Configuration File)
// Severity: critical
// Response: Delete file, purge site-packages, reinstall clean litellm

rule TeamPCP_PTH_Hook_File
{
    meta:
        description   = "Detects litellm_init.pth malicious .pth hook: Python exec imports + C2
domains or artifact paths"
        author        = "Mazlum BAYDAR"
        date          = "2026-03-26"
        severity      = "critical"
        mitre_attack  = "T1546.018"
        reference     = "https://futuresearch.ai/blog/litellm-pypi-supply-chain-attack/"

    strings:
        /* Python execution imports required in any .pth exec hook */
        $pth_import1  = "import subprocess" ascii nocase
        $pth_import2  = "import os" ascii nocase
        $pth_import3  = "import sys" ascii nocase

        /* TeamPCP C2 domains embedded in payload */
        $c2_domain1   = "models.litellm.cloud" ascii wide
        $c2_domain2   = "checkmarx.zone" ascii wide

        /* TeamPCP artifact paths referenced by the hook */
        $artifact1    = ".config/sysmon/sysmon.py" ascii
        $artifact2    = ".config/systemd/user/sysmon.service" ascii
        $artifact3    = "/tmp/pglog" ascii
        $artifact4    = "/tmp/.pg_state" ascii
        $artifact5    = "tpcp.tar.gz" ascii

    condition:
        /* .pth exec hook: Python import + C2 reference */
```

```
        (any of ($pth_import*) and any of ($c2_domain*))
        or
        /* .pth exec hook: Python import + artifact path */
        (any of ($pth_import*) and any of ($artifact*))
        or
        /* Any two artifact indicators together (strong signal) */
        2 of ($artifact*)
}

// ─── RULE 2: TeamPCP_Backdoor_And_Persistence ───
// Combined rule matching EITHER sysmon.py backdoor script content OR
// sysmon.service systemd unit content. Uses any of ($backdoor_*) and
// any of ($service_*) grouped conditions to cover both in one rule.
// MITRE: T1036.005 (Masquerading), T1547.016 (systemd Persistence)
// Severity: high
// Response: Kill Python processes, disable service unit, remove files, check crontabs

rule TeamPCP_Backdoor_And_Persistence
{
    meta:
        description   = "Detects TeamPCP sysmon.py backdoor script OR sysmon.service systemd
persistence unit content"
        author        = "Mazlum BAYDAR"
        date          = "2026-03-26"
        severity      = "high"
        mitre_attack  = "T1036.005, T1547.016"
        reference     = "https://securitylabs.datadoghq.com/articles/litellm-compromised-pypi-
teampcp-supply-chain-campaign/"

    strings:
        /* sysmon.py backdoor — beacon + command execution patterns */
        $backdoor_c2a = "checkmarx.zone" ascii wide
        $backdoor_c2b = "models.litellm.cloud" ascii wide
        $backdoor_st1 = "/tmp/.pg_state" ascii
        $backdoor_st2 = "/tmp/pglog" ascii
        $backdoor_ex1 = "subprocess" ascii
        $backdoor_ex2 = "base64" ascii

        /* sysmon.service systemd unit — structural markers + backdoor reference */
        $service_u1   = "[Unit]" ascii
        $service_s1   = "[Service]" ascii
        $service_e1   = "ExecStart" ascii
        $service_py   = "sysmon.py" ascii
        $service_w1   = "WantedBy" ascii

    condition:
        /* Backdoor script: C2 domain + state file + execution primitive */
        (any of ($backdoor_c2*) and any of ($backdoor_st*) and any of ($backdoor_ex*))
        or
        /* systemd service unit pointing to backdoor */
        (all of ($service_u1, $service_s1, $service_e1, $service_py))
}

// ─── RULE 3: TeamPCP_Malicious_PyPI_Package ───
// Matches Python package METADATA or dist-info files containing the
// malicious version strings (1.82.7 or 1.82.8) alongside the .pth hook
```

```
// filename reference or embedded C2 endpoints. Targets files on disk
// in the package distribution: METADATA, PKG-INFO, setup.py, RECORD.
// MITRE: T1195.001 (Supply Chain Compromise — PyPI package)
// Severity: critical
// Response: Uninstall package, verify pip cache integrity, rotate credentials

rule TeamPCP_Malicious_PyPI_Package
{
    meta:
        description   = "Detects TeamPCP IOCs in litellm package METADATA/dist-info: malicious
version + .pth ref or C2 domains"
        author        = "Mazlum BAYDAR"
        date          = "2026-03-26"
        severity      = "critical"
        mitre_attack  = "T1195.001"
        reference     = "https://sysdig.com/blog/teampcp-pypi-supply-chain/"

    strings:
        /* Malicious version strings in package METADATA */
        $ver_1        = "Version: 1.82.7" ascii
        $ver_2        = "Version: 1.82.8" ascii

        /* .pth hook filename as data_files entry */
        $pth_ref      = "litellm_init.pth" ascii

        /* C2 endpoints hardcoded in package source */
        $c2_1         = "models.litellm.cloud" ascii wide
        $c2_2         = "checkmarx.zone" ascii wide

    condition:
        /* Malicious version with .pth hook reference */
        (1 of ($ver_*) and $pth_ref)
        or
        /* Malicious version with embedded C2 */
        (1 of ($ver_*) and 1 of ($c2_*))
        or
        /* .pth hook file + C2 (catches payload files directly) */
        ($pth_ref and 1 of ($c2_*))
}
```

K **KQL** Microsoft Defender XDR · Sentinel

Four KQL queries: consolidated process detection covering all pip invocation patterns, a single file artifacts query using has_any() across all TeamPCP file indicators, combined C2 query covering both domains and IPs, and a kill chain correlation join. Time ranges default to 7 days.

```
// CVE-2026-33634 — LiteLLM PyPI Supply Chain Attack (TeamPCP)
// CVSS 9.4 Critical | Platform: Microsoft Defender XDR + Microsoft Sentinel
// ATT&CK: T1195.001, T1546.018, T1547.016, T1041, T1552
// Severity: Critical | Response: Isolate device, revoke creds, escalate to IR
// Author: Mazlum BAYDAR | Date: 2026-03-26

// ─── RULE 1: TeamPCP_Malicious_LiteLLM_Install ───
// Detects pip, pip3, python, or python3 process installing backdoored litellm
// versions 1.82.7 or 1.82.8 using has_any for both version strings.
// Covers direct pip and python -m pip invocations in a single query.
// MITRE: T1195.001 | Severity: critical
// Response: Block process, isolate DeviceId, purge pip cache

DeviceProcessEvents
| where Timestamp > ago(7d)
| where FileName has_any ("pip", "pip3", "python", "python3")
| where ProcessCommandLine has_any ("litellm==1.82.7", "litellm==1.82.8")
| project Timestamp, DeviceName, DeviceId, AccountName,
          FileName, ProcessCommandLine,
          InitiatingProcessFileName, InitiatingProcessCommandLine, FolderPath
| order by Timestamp desc

// ─── RULE 2: TeamPCP_Artifact_Files ───
// Single consolidated file event query covering all five TeamPCP artifacts:
// litellm_init.pth (.pth hook), sysmon.py (backdoor), sysmon.service
// (systemd persistence), pglog (payload staging), .pg_state (infection state).
// Filters on FileName AND FolderPath to minimize false positives.
// MITRE: T1546.018, T1036.005, T1547.016 | Severity: critical
// Response: Collect for forensics, kill python processes, remove persistence

DeviceFileEvents
| where Timestamp > ago(7d)
| where ActionType in ("FileCreated", "FileModified")
| where (FileName == "litellm_init.pth" and FolderPath has "site-packages")
      or (FileName == "sysmon.py" and FolderPath has ".config/sysmon")
      or (FileName == "sysmon.service" and FolderPath has ".config/systemd/user")
      or (FileName has_any ("pglog", ".pg_state") and FolderPath has "/tmp")
| project Timestamp, DeviceName, DeviceId, AccountName,
          FileName, FolderPath, ActionType,
          InitiatingProcessFileName, InitiatingProcessCommandLine,
          SHA1, MD5
| order by Timestamp desc

// ─── RULE 3: TeamPCP_C2_Communication ───
// Unified C2 detection using union of IP-based and domain-based network events.
// Covers both confirmed C2 IPs (45.148.10.212, 83.142.209.11) and C2 domains
// (any .litellm.cloud subdomain, checkmarx.zone) in a single result set.
```

```
// MITRE: T1041 | Severity: critical
// Response: Block IPs/domains at firewall, capture PCAP, isolate host

union
    (
        DeviceNetworkEvents
        | where Timestamp > ago(7d)
        | where RemoteIP in ("45.148.10.212", "83.142.209.11")
        | extend DetectionType = "C2_IP"
    ),
    (
        DeviceNetworkEvents
        | where Timestamp > ago(7d)
        | where RemoteUrl has_any (".litellm.cloud", "checkmarx.zone")
        | extend DetectionType = "C2_Domain"
    )
| project Timestamp, DeviceName, DeviceId, AccountName,
          DetectionType, RemoteIP, RemoteUrl, RemotePort,
          InitiatingProcessFileName, InitiatingProcessCommandLine, ActionType
| order by Timestamp desc

// ─── RULE 4: TeamPCP_Kill_Chain_Correlation ───
// Joins pip install events with subsequent network C2 events on the same device.
// High-confidence: device that ran malicious install AND made C2 contact.
// MITRE: T1195.001 + T1041 | Severity: critical
// Response: Immediate host isolation, full disk forensics, credential rotation

let MaliciousInstalls = DeviceProcessEvents
    | where Timestamp > ago(7d)
    | where FileName has_any ("pip", "pip3", "python", "python3")
    | where ProcessCommandLine has_any ("litellm==1.82.7", "litellm==1.82.8")
    | project DeviceId, DeviceName, AccountName,
              InstallTime = Timestamp, InstallCmdLine = ProcessCommandLine;
let C2Events = DeviceNetworkEvents
    | where Timestamp > ago(7d)
    | where RemoteIP in ("45.148.10.212", "83.142.209.11")
          or RemoteUrl has_any (".litellm.cloud", "checkmarx.zone")
    | project DeviceId, C2Time = Timestamp,
              RemoteIP, RemoteUrl, RemotePort,
              C2Process = InitiatingProcessFileName;
MaliciousInstalls
| join kind=inner C2Events on DeviceId
| where C2Time ≥ InstallTime
| project DeviceName, AccountName, InstallTime, InstallCmdLine,
          C2Time, RemoteIP, RemoteUrl, RemotePort, C2Process
| order by InstallTime desc
```

X **XQL** Palo Alto Cortex XDR · XSIAM

Four XQL stage-based pipeline queries using ENUM constants: process installation detection, consolidated file artifacts query, combined C2 network and DNS query, and a process-to-network correlation rule. Uses correct ENUM.PROCESS, ENUM.FILE, ENUM.NETWORK event type constants.

```
// CVE-2026-33634 — LiteLLM PyPI Supply Chain Attack (TeamPCP)
// CVSS 9.4 Critical | Platform: Palo Alto Cortex XDR / XSIAM
// ATT&CK: T1195.001, T1546.018, T1547.016, T1041, T1552
// Severity: Critical | Response: Isolate endpoint, revoke creds, escalate IR
// Author: Mazlum BAYDAR | Date: 2026-03-26
// Note: XQL uses RE2 regex engine (~= operator); ENUM constants for event types

// ── RULE 1: TeamPCP_Malicious_LiteLLM_Install ──
// Detects pip, pip3, python, or python3 installing backdoored litellm 1.82.7/1.82.8.
// RE2 regex combines both version strings in a single pattern for efficiency.
// Covers direct pip and python -m pip install invocations.
// MITRE: T1195.001 | Severity: critical
// Response: Terminate process, isolate agent, purge pip cache

dataset = xdr_data
| filter event_type = ENUM.PROCESS and event_sub_type = ENUM.PROCESS_START
| filter actor_process_image_name in ("pip", "pip3", "python", "python3")
        and actor_process_command_line ~= "litellm==(1\.82\.7|1\.82\.8)"
| fields timestamp_desc, agent_hostname, actor_primary_username,
         actor_process_image_name, actor_process_command_line,
         actor_process_image_path, causality_actor_process_image_name
| sort desc timestamp_desc
| limit 100

// ── RULE 2: TeamPCP_Artifact_Files ──
// Single consolidated file event query for all TeamPCP artifacts.
// Covers litellm_init.pth (.pth hook in site-packages), sysmon.py (backdoor
// in .config/sysmon), sysmon.service (systemd persistence), and /tmp staging
// files pglog and .pg_state — all in one filter pipeline.
// MITRE: T1546.018, T1036.005, T1547.016 | Severity: critical
// Response: Collect files, kill Python, disable systemd unit, forensic image

dataset = xdr_data
| filter event_type = ENUM.FILE and event_sub_type = ENUM.FILE_CREATE_NEW
| filter (action_file_name = "litellm_init.pth" and action_file_path contains "site-packages")
      or (action_file_name = "sysmon.py" and action_file_path contains ".config/sysmon")
      or (action_file_name = "sysmon.service" and action_file_path contains
".config/systemd/user")
      or action_file_path in ("/tmp/pglog", "/tmp/.pg_state")
| fields timestamp_desc, agent_hostname, actor_primary_username,
         action_file_name, action_file_path,
         actor_process_image_name, actor_process_command_line
| sort desc timestamp_desc
| limit 100

// ── RULE 3: TeamPCP_C2_Communication ──
// Combined C2 detection covering both IP-based and domain-based indicators
```

```
// in a single network event filter. Matches confirmed C2 IPs and any
// .litellm.cloud subdomain or checkmarx.zone host.
// MITRE: T1041 | Severity: critical
// Response: Block IPs/domains, capture traffic, isolate agent immediately

dataset = xdr_data
| filter event_type = ENUM.NETWORK
| filter dst_ip in ("45.148.10.212", "83.142.209.11")
      or dst_host ~= "(.*\.litellm\.cloud|checkmarx\.zone)$"
| fields timestamp_desc, agent_hostname, actor_primary_username,
         actor_process_image_name, actor_process_command_line,
         dst_host, dst_ip, dst_port, protocol
| sort desc timestamp_desc
| limit 100

// ─── RULE 4: TeamPCP_Kill_Chain_Correlation ───
// Sequential pipeline: identifies Python processes that made C2 network
// connections after a malicious install event on the same agent.
// Uses join on agent_id to correlate process start → C2 network contact.
// MITRE: T1195.001 + T1041 | Severity: critical
// Response: Immediate isolation, full disk image, credential rotation

dataset = xdr_data
| filter event_type = ENUM.PROCESS and event_sub_type = ENUM.PROCESS_START
| filter actor_process_image_name in ("pip", "pip3", "python", "python3")
        and actor_process_command_line ~= "litellm==(1\.82\.7|1\.82\.8)"
| fields agent_id, agent_hostname, actor_primary_username,
         install_time = timestamp_desc,
         install_cmd = actor_process_command_line
| join (
    dataset = xdr_data
    | filter event_type = ENUM.NETWORK
    | filter dst_ip in ("45.148.10.212", "83.142.209.11")
          or dst_host ~= "(.*\.litellm\.cloud|checkmarx\.zone)$"
    | fields agent_id, c2_time = timestamp_desc,
             c2_process = actor_process_image_name,
             dst_ip, dst_host, dst_port
  ) as c2
  on agent_id
| fields agent_hostname, actor_primary_username,
         install_time, install_cmd,
         c2_time, c2_process, dst_ip, dst_host, dst_port
| sort desc install_time
| limit 100
```

S **Splunk SPL** Splunk SIEM · Sysmon Add-On

Four Splunk queries using Sysmon event codes: process creation (EventCode=1) covering all pip patterns, file creation (EventCode=11) with all TeamPCP artifacts in one query, combined DNS and network events (EventCode=22 OR 3), and a host-level correlation aggregation query.

```
| Comment "CVE-2026-33634 — LiteLLM PyPI Supply Chain Attack (TeamPCP)"
| Comment "CVSS 9.4 Critical | Platform: Splunk (Sysmon for Linux + Sysmon/Operational)"
| Comment "ATT&CK: T1195.001, T1546.018, T1547.016, T1041, T1552"
| Comment "Severity: Critical | Response: Isolate host, revoke pip cache, escalate IR"
| Comment "Author: Mazlum BAYDAR | Date: 2026-03-26"
| Comment "Field mapping: Sysmon TA CIM — EventCode 1=Process, 3=Network, 11=FileCreate, 22=DNS"

| Comment "─── RULE 1: TeamPCP_Malicious_LiteLLM_Install ───"
| Comment "Detects pip, pip3, python, or python3 installing litellm 1.82.7 or 1.82.8."
| Comment "Single EventCode=1 query combining all invocation patterns and both version strings."
| Comment "MITRE: T1195.001 | Severity: critical"
| Comment "Response: Block process, isolate host, purge pip cache"

index=linux_logs OR index=sysmon
sourcetype=xmlwineventlog:microsoft-windows-sysmon/operational EventCode=1
(Image="*/pip" OR Image="*/pip3" OR Image="*/python" OR Image="*/python3")
(CommandLine="*litellm==1.82.7*" OR CommandLine="*litellm==1.82.8*")
| rename ComputerName AS host, User AS user, Image AS process,
         CommandLine AS cmdline, ParentImage AS parent_process
| table _time, host, user, process, cmdline, parent_process
| sort - _time

| Comment "─── RULE 2: TeamPCP_Artifact_Files ───"
| Comment "Single EventCode=11 query covering all five TeamPCP artifact files:"
| Comment "litellm_init.pth (.pth hook), sysmon.py (backdoor), sysmon.service (systemd),"
| Comment "/tmp/pglog (payload staging), /tmp/.pg_state (infection state)."
| Comment "MITRE: T1546.018, T1036.005, T1547.016 | Severity: critical"
| Comment "Response: Collect artifacts, kill python, disable service unit"

index=linux_logs OR index=sysmon
sourcetype=xmlwineventlog:microsoft-windows-sysmon/operational EventCode=11
(TargetFilename="*site-packages*litellm_init.pth"
 OR TargetFilename="*/.config/sysmon/sysmon.py"
 OR TargetFilename="*/.config/systemd/user/sysmon.service"
 OR TargetFilename="/tmp/pglog"
 OR TargetFilename="/tmp/.pg_state")
| rename ComputerName AS host, User AS user, Image AS process, TargetFilename AS file_path
| table _time, host, user, process, file_path
| sort - _time

| Comment "─── RULE 3: TeamPCP_C2_Indicators ───"
| Comment "Unified C2 query combining EventCode=22 (DNS) and EventCode=3 (network conn)."
| Comment "Covers both C2 domains (.litellm.cloud, checkmarx.zone) and C2 IPs"
| Comment "(45.148.10.212, 83.142.209.11) in a single query using OR EventCode."
| Comment "MITRE: T1041 | Severity: critical"
| Comment "Response: Block domains/IPs at perimeter, capture PCAP, isolate host"
```

```
index=linux_logs OR index=sysmon
sourcetype=xmlwineventlog:microsoft-windows-sysmon/operational
((EventCode=22 AND (QueryName="*litellm.cloud" OR QueryName="checkmarx.zone" OR
QueryName="*.checkmarx.zone"))
 OR (EventCode=3 AND (DestinationIp="45.148.10.212" OR DestinationIp="83.142.209.11")))
| eval indicator=case(
    EventCode="22", "DNS:".QueryName,
    EventCode="3",  "IP:".DestinationIp,
    true(), "unknown")
| rename ComputerName AS host, User AS user, Image AS process
| table _time, host, user, process, EventCode, indicator
| sort - _time

| Comment "─── RULE 4: TeamPCP_Host_Correlation ───"
| Comment "Aggregation query across EventCodes 1, 3, and 22 to surface hosts with"
| Comment "multiple IOC hits. A host appearing in more than one EventCode category"
| Comment "is high-confidence infected. Stats pivot groups by host and event type."
| Comment "MITRE: T1195.001 + T1041 | Severity: critical"
| Comment "Response: Priority triage — hosts with count ≥ 2 event types require immediate IR"

index=linux_logs OR index=sysmon
sourcetype=xmlwineventlog:microsoft-windows-sysmon/operational
((EventCode=1 AND (CommandLine="*litellm==1.82.7*" OR CommandLine="*litellm==1.82.8*"))
 OR (EventCode=3 AND (DestinationIp="45.148.10.212" OR DestinationIp="83.142.209.11"))
 OR (EventCode=22 AND (QueryName="*litellm.cloud" OR QueryName="checkmarx.zone")))
| rename ComputerName AS host
| eval ioc_type=case(
    EventCode="1",  "malicious_install",
    EventCode="3",  "c2_ip_connection",
    EventCode="22", "c2_dns_query",
    true(), "other")
| stats count AS hit_count, values(ioc_type) AS ioc_types, dc(ioc_type) AS ioc_categories
    by host
| sort - ioc_categories, - hit_count
```

Q QRadar AQL

IBM QRadar SIEM

Four AQL queries using SQL-like syntax with ILIKE for case-insensitive matching: process detection, combined file artifact search, C2 indicators combined with UNION, and an aggregation query grouping all IOC hits by source IP. Uses QIDNAME() and LOGSOURCENAME() for enriched output.

```
-- CVE-2026-33634 — LiteLLM PyPI Supply Chain Attack (TeamPCP)
-- CVSS 9.4 Critical | Platform: IBM QRadar SIEM
-- ATT&CK: T1195.001, T1546.018, T1547.016, T1041, T1552
-- Severity: Critical | Response: Isolate source IP, revoke creds, escalate IR
-- Author: Mazlum BAYDAR | Date: 2026-03-26
-- Note: ILIKE = case-insensitive pattern (% wildcard); IN = exact list match
--       destinationIP is a parsed QRadar field; "Message" is raw event payload

-- ─── RULE 1: TeamPCP_Malicious_LiteLLM_Install ───
-- Detects pip or python process audit events containing litellm==1.82.7 or 1.82.8.
-- Single ILIKE OR query covers all invocation patterns from the raw Message field.
-- MITRE: T1195.001 | Severity: critical
-- Response: Block source IP, quarantine endpoint, purge pip cache

SELECT
    DATEFORMAT(devicetime, 'yyyy-MM-dd HH:mm:ss') AS event_time,
    LOGSOURCENAME(logsourceid)                    AS log_source,
    sourceIP,
    username,
    "Message"                                     AS command_line
FROM events
WHERE devicetime > CURRENT_TIMESTAMP - 7 DAYS
  AND ("Message" ILIKE '%litellm==1.82.7%'
       OR "Message" ILIKE '%litellm==1.82.8%')
ORDER BY devicetime DESC
LIMIT 500

-- ─── RULE 2: TeamPCP_Artifact_Files ───
-- Consolidated ILIKE OR query for all five TeamPCP artifact file paths.
-- Covers litellm_init.pth, sysmon.py, sysmon.service, /tmp/pglog, /tmp/.pg_state.
-- MITRE: T1546.018, T1036.005, T1547.016 | Severity: critical
-- Response: Collect files, kill python processes, remove persistence units

SELECT
    DATEFORMAT(devicetime, 'yyyy-MM-dd HH:mm:ss') AS event_time,
    LOGSOURCENAME(logsourceid)                    AS log_source,
    sourceIP,
    username,
    "Message"                                     AS file_event
FROM events
WHERE devicetime > CURRENT_TIMESTAMP - 7 DAYS
  AND ("Message" ILIKE '%site-packages%litellm_init.pth%'
       OR "Message" ILIKE '%/.config/sysmon/sysmon.py%'
       OR "Message" ILIKE '%/.config/systemd/user/sysmon.service%'
       OR "Message" ILIKE '%/tmp/pglog%'
       OR "Message" ILIKE '%/tmp/.pg_state%')
ORDER BY devicetime DESC
```

```
LIMIT 200

-- ─── RULE 3: TeamPCP_C2_Communication ───
-- UNION of DNS domain matching (ILIKE on Message) and IP matching (destinationIP IN).
-- Covers both C2 vectors in one result set: domain-based and direct IP C2.
-- MITRE: T1041 | Severity: critical
-- Response: Block IPs/domains at perimeter, capture traffic, isolate host

SELECT
    DATEFORMAT(devicetime, 'yyyy-MM-dd HH:mm:ss') AS event_time,
    LOGSOURCENAME(logsourceid)                    AS log_source,
    sourceIP,
    destinationIP,
    username,
    'C2_Domain'                                   AS indicator_type,
    "Message"                                     AS event_detail
FROM events
WHERE devicetime > CURRENT_TIMESTAMP - 7 DAYS
  AND ("Message" ILIKE '%litellm.cloud%'
       OR "Message" ILIKE '%checkmarx.zone%')

UNION ALL

SELECT
    DATEFORMAT(devicetime, 'yyyy-MM-dd HH:mm:ss') AS event_time,
    LOGSOURCENAME(logsourceid)                    AS log_source,
    sourceIP,
    destinationIP,
    username,
    'C2_IP'                                       AS indicator_type,
    "Message"                                     AS event_detail
FROM events
WHERE devicetime > CURRENT_TIMESTAMP - 7 DAYS
  AND destinationIP IN ('45.148.10.212', '83.142.209.11')

ORDER BY event_time DESC
LIMIT 500

-- ─── RULE 4: TeamPCP_Aggregated_IOC_Hits ───
-- Groups all IOC hits by sourceIP with counts and first/last seen timestamps.
-- A single sourceIP matching multiple IOC categories is high-confidence compromised.
-- MITRE: T1195.001 + T1041 | Severity: critical
-- Response: Prioritize sourceIPs with hit_count ≥ 3 for immediate IR triage

SELECT
    sourceIP,
    COUNT(*)                                                    AS hit_count,
    MIN(DATEFORMAT(devicetime, 'yyyy-MM-dd HH:mm:ss'))          AS first_seen,
    MAX(DATEFORMAT(devicetime, 'yyyy-MM-dd HH:mm:ss'))          AS last_seen,
    username
FROM events
WHERE devicetime > CURRENT_TIMESTAMP - 7 DAYS
  AND (destinationIP IN ('45.148.10.212', '83.142.209.11')
       OR "Message" ILIKE '%litellm.cloud%'
       OR "Message" ILIKE '%checkmarx.zone%'
       OR "Message" ILIKE '%litellm_init.pth%'
```

```
        OR "Message" ILIKE '%litellm==1.82.7%'
        OR "Message" ILIKE '%litellm==1.82.8%')
GROUP BY sourceIP, username
ORDER BY hit_count DESC
LIMIT 100
```

C **Carbon Black** VMware Carbon Black Cloud

Four consolidated Lucene-based Carbon Black watchlist queries: process detection combining pip and python invocations, all file artifacts in one query using OR logic, C2 domains and IPs combined in one query, and a Python+C2 correlation query. All regex patterns use lowercase as required by CBC's index.

```
# CVE-2026-33634 — LiteLLM PyPI Supply Chain Attack (TeamPCP)
# CVSS 9.4 Critical | Platform: VMware Carbon Black Cloud (CBC)
# ATT&CK: T1195.001, T1546.018, T1547.016, T1041, T1552
# Severity: Critical | Response: Isolate device, revoke creds, escalate IR
# Author: Mazlum BAYDAR | Date: 2026-03-26
#
# CBC SYNTAX NOTES:
#   - All indexed text is lowercase — regex must use lowercase patterns
#   - Paths use forward slashes; wildcard (*) works in single terms only
#   - Implicit AND between terms; explicit OR/NOT required
#   - Regex via field:/pattern/ uses Java regex engine (lowercase text)

# ── RULE 1: TeamPCP_Malicious_LiteLLM_Install ──
# Detects pip, pip3, and python/python3 -m pip installing litellm 1.82.7 or 1.82.8.
# Single OR query combining all process names with both version cmdline strings.
# MITRE: T1195.001 | Severity: critical
# Response: Block process, isolate device, audit installed packages

(process_name:pip OR process_name:pip3 OR process_name:python OR process_name:python3)
AND (cmdline:"litellm==1.82.7" OR cmdline:"litellm==1.82.8")

# ── RULE 2: TeamPCP_Artifact_Files ──
# Covers all five TeamPCP artifact files in one OR query.
# litellm_init.pth (.pth hook), sysmon.py (backdoor), sysmon.service (systemd),
# /tmp/pglog (payload staging), /tmp/.pg_state (infection state).
# MITRE: T1546.018, T1036.005, T1547.016 | Severity: critical
# Response: Collect artifacts, kill python processes, remove persistence units

(filemod_name:"litellm_init.pth"
 OR filemod_name:*/.config/sysmon/sysmon.py
 OR filemod_name:*/.config/systemd/user/sysmon.service
 OR filemod_name:"/tmp/pglog"
 OR filemod_name:"/tmp/.pg_state")

# ── RULE 3: TeamPCP_C2_Communication ──
# Combined C2 detection covering both domain-based and IP-based indicators.
# Matches confirmed C2 domains (models.litellm.cloud, checkmarx.zone) and
# confirmed C2 IPs (45.148.10.212, 83.142.209.11) in a single OR query.
# MITRE: T1041 | Severity: critical
# Response: Block at firewall, capture PCAP, isolate device immediately

(netconn_domain:models.litellm.cloud OR netconn_domain:*.litellm.cloud
 OR netconn_domain:checkmarx.zone OR netconn_domain:*.checkmarx.zone)
OR (netconn_ipv4:45.148.10.212 OR netconn_ipv4:83.142.209.11)

# ── RULE 4: TeamPCP_Python_C2_Correlation ──
# High-confidence: Python or pip process making C2 network connection.
```

```
# Correlates process identity (python/python3) with confirmed C2 indicators
# to surface active backdoor beaconing vs. passive install artifacts.
# MITRE: T1041, T1552 | Severity: critical
# Response: Immediate isolation, full disk forensics, credential rotation

(process_name:python OR process_name:python3)
AND (netconn_domain:models.litellm.cloud OR netconn_domain:*.litellm.cloud
     OR netconn_domain:checkmarx.zone
     OR netconn_ipv4:45.148.10.212 OR netconn_ipv4:83.142.209.11)
```

S1 SentinelOne Deep Visibility

v2 Enhanced · STAR Rules

Four SentinelOne DV v2 queries using dot notation (TgtFile.Path, DnsRequest.Name, Dst.IP): process creation detection, all file artifacts combined with OR, C2 DNS and network events combined in one query, and a kill chain composite query. Uses Contains (case-insensitive) and In Contains operators appropriately.

```
// CVE-2026-33634 — LiteLLM PyPI Supply Chain Attack (TeamPCP)
// CVSS 9.4 Critical | Platform: SentinelOne Deep Visibility (DV v2 Enhanced)
// ATT&CK: T1195.001, T1546.018, T1547.016, T1041, T1552
// Severity: Critical | Response: Isolate endpoint, revoke creds, escalate IR
// Author: Mazlum BAYDAR | Date: 2026-03-26
//
// S1 SYNTAX NOTES:
//   - EventType is a case-sensitive string in double quotes
//   - Dot notation required: TgtFile.Path, DnsRequest.Name, Dst.IP
//   - Contains = case-insensitive substring match
//   - In Contains = case-insensitive contains check against a list
//   - EndsWith, StartsWith = case-sensitive
//   - In = exact case-insensitive match against a list

// ─── RULE 1: TeamPCP_Malicious_LiteLLM_Install ───
// Detects Process Creation events where pip/pip3 or python/python3 installs
// litellm version 1.82.7 or 1.82.8. Combines process name check (target or
// source process) with cmdline version string using Contains (case-insensitive).
// MITRE: T1195.001 | Severity: critical
// Response: Kill process, isolate endpoint, purge pip cache

EventType = "Process Creation"
AND (TgtProcCmdLine Contains "litellm==1.82.7" OR TgtProcCmdLine Contains "litellm==1.82.8")
AND (TgtProcName In Contains ("pip", "pip3", "python", "python3")
     OR SrcProcName In Contains ("pip", "pip3", "python", "python3"))

// ─── RULE 2: TeamPCP_Artifact_Files ───
// Consolidated File Creation/Modification rule covering all five TeamPCP artifacts.
// Uses TgtFile.Path Contains for path-based matching across all artifact locations:
// site-packages (pth hook), .config/sysmon (backdoor), .config/systemd/user
// (persistence), tmp/pglog and tmp/.pg_state (staging/state).
// MITRE: T1546.018, T1036.005, T1547.016 | Severity: critical
// Response: Collect file, kill python, disable service, forensic image

EventType In ("File Creation", "File Modification")
AND (TgtFile.Path Contains "site-packages/litellm_init.pth"
     OR TgtFile.Path Contains ".config/sysmon/sysmon.py"
     OR TgtFile.Path Contains ".config/systemd/user/sysmon.service"
     OR TgtFile.Path Contains "tmp/pglog"
     OR TgtFile.Path Contains "tmp/.pg_state")

// ─── RULE 3: TeamPCP_C2_Communication ───
// Combined C2 detection covering both DNS and direct IP vectors in one query.
// DNS Request matches any .litellm.cloud subdomain and checkmarx.zone.
// IP Connect matches confirmed C2 IPs 45.148.10.212 and 83.142.209.11.
// MITRE: T1041 | Severity: critical
// Response: Block at DNS/firewall, capture PCAP, isolate endpoint immediately
```

```
(EventType = "DNS Request"
 AND (DnsRequest.Name Contains "litellm.cloud" OR DnsRequest.Name Contains "checkmarx.zone"))
OR
(EventType = "IP Connect"
 AND Dst.IP In ("45.148.10.212", "83.142.209.11"))

// ─── RULE 4: TeamPCP_Kill_Chain_Composite ───
// High-confidence composite rule combining all primary IOC classes.
// Surfaces process install OR file artifacts OR DNS C2 OR IP C2 in one query.
// Use in alert mode: any single match warrants investigation; two or more = IR.
// MITRE: T1195.001, T1546.018, T1041 | Severity: critical
// Response: Immediate isolation, full IR, credential rotation for affected users

(
  (EventType = "Process Creation"
   AND TgtProcCmdLine In Contains ("litellm==1.82.7", "litellm==1.82.8"))
  OR
  (EventType In ("File Creation", "File Modification")
   AND TgtFile.Name In ("litellm_init.pth", "sysmon.py", "sysmon.service"))
  OR
  (EventType = "DNS Request"
   AND (DnsRequest.Name Contains "litellm.cloud" OR DnsRequest.Name Contains "checkmarx.zone"))
  OR
  (EventType = "IP Connect"
   AND Dst.IP In ("45.148.10.212", "83.142.209.11"))
)
```

K **Kaspersky EDR Expert** KEDR · KATA

Five KEDR queries using UPPERCASE operator convention: process detection, combined file artifacts using OR, combined network C2 query covering domains and IPs, process-to-network correlation, and a comprehensive composite rule covering all IOC classes in one query. Avoids TAA reserved fields per official documentation.

```
// CVE-2026-33634 — LiteLLM PyPI Supply Chain Attack (TeamPCP)
// CVSS 9.4 Critical | Platform: Kaspersky EDR Expert (KEDR) / KATA
// ATT&CK: T1195.001, T1546.018, T1547.016, T1041, T1552
// Severity: Critical | Response: Isolate host, revoke creds, escalate IR
// Author: Mazlum BAYDAR | Date: 2026-03-26
//
// KEDR SYNTAX NOTES:
//   - ALL operators UPPERCASE: CONTAINS, STARTS_WITH, ENDS_WITH, IN, MATCHES, AND, OR, NOT
//   - Field dot notation: Process.Name, Process.CommandLine, File.Path, File.Name
//     Network.DestinationIP, Network.DestinationHost
//   - CONTAINS, ENDS_WITH, STARTS_WITH, IN = case-insensitive
//   - MATCHES = full PCRE regex, case-sensitive by default
//   - String values in double quotes; group with parentheses

// ── RULE 1: TeamPCP_Malicious_LiteLLM_Install ──
// Detects pip, pip3, python, or python3 process installing backdoored litellm.
// Process.Name CONTAINS covers binary path suffixes; both version strings in OR.
// MITRE: T1195.001 | Severity: critical
// Response: Terminate process, isolate host, purge pip cache, audit all Python envs

(Process.Name CONTAINS "pip" OR Process.Name CONTAINS "python")
AND (Process.CommandLine CONTAINS "litellm==1.82.7"
     OR Process.CommandLine CONTAINS "litellm==1.82.8")

// ── RULE 2: TeamPCP_Artifact_Files ──
// Consolidated rule covering all five TeamPCP artifact files using OR conditions.
// File.Path CONTAINS matches across all subdirectories; File.Name IN for /tmp files.
// MITRE: T1546.018, T1036.005, T1547.016 | Severity: critical
// Response: Delete artifacts, kill python processes, disable systemd unit, forensic image

(File.Path CONTAINS "litellm_init.pth"
 OR File.Path CONTAINS ".config/sysmon/sysmon.py"
 OR File.Path CONTAINS ".config/systemd/user/sysmon.service"
 OR File.Name IN ("pglog", ".pg_state"))

// ── RULE 3: TeamPCP_C2_Communication ──
// Combined C2 detection for both domain-based and IP-based indicators.
// Network.DestinationHost ENDS_WITH covers all .litellm.cloud subdomains.
// Network.DestinationIP IN matches both confirmed C2 server IPs.
// MITRE: T1041 | Severity: critical
// Response: Block IPs/domains at network layer, capture traffic, isolate host

(Network.DestinationHost IN ("models.litellm.cloud", "checkmarx.zone")
 OR Network.DestinationHost ENDS_WITH ".litellm.cloud"
 OR Network.DestinationIP IN ("45.148.10.212", "83.142.209.11"))

// ── RULE 4: TeamPCP_Python_C2_Correlation ──
```

```
// Correlated rule: Python or pip process making outbound C2 network connection.
// High-confidence indicator of active backdoor beaconing by sysmon.py.
// MITRE: T1041, T1552 | Severity: critical
// Response: Immediate isolation, full disk forensics, rotate all user credentials

(Process.Name CONTAINS "python" OR Process.Name CONTAINS "pip")
AND (Network.DestinationHost IN ("models.litellm.cloud", "checkmarx.zone")
     OR Network.DestinationHost ENDS_WITH ".litellm.cloud"
     OR Network.DestinationIP IN ("45.148.10.212", "83.142.209.11"))

// ─── RULE 5: TeamPCP_Comprehensive_Composite ───
// Master composite rule combining all IOC classes for high-coverage alerting.
// Matches any one of: malicious install cmdline, artifact files, or C2 activity.
// Tune alert threshold in KEDR console; each class independently confirms infection.
// MITRE: T1195.001, T1546.018, T1547.016, T1041 | Severity: critical
// Response: Triage by IOC class; all matches warrant investigation; C2 = immediate IR

(
  (Process.CommandLine CONTAINS "litellm==1.82.7"
   OR Process.CommandLine CONTAINS "litellm==1.82.8")
  OR
  (File.Path CONTAINS "litellm_init.pth"
   OR File.Path CONTAINS ".config/sysmon/sysmon.py"
   OR File.Path CONTAINS ".config/systemd/user/sysmon.service"
   OR File.Name IN ("pglog", ".pg_state"))
  OR
  (Network.DestinationHost IN ("models.litellm.cloud", "checkmarx.zone")
   OR Network.DestinationHost ENDS_WITH ".litellm.cloud"
   OR Network.DestinationIP IN ("45.148.10.212", "83.142.209.11"))
)
```

CS **CrowdStrike Falcon NG-SIEM** LogScale CQL · Custom IOA

Four consolidated CQL hunting queries plus four Custom IOA behavioral prevention rules (JSON format, deployable via Falcon API). CQL queries combine related detections: install + artifact drop, DNS C2 + IP connections, full kill chain correlation, Python subprocess spawning. IOA rules run on the sensor at kernel level â€" blocking before OS execution.

```
// CVE-2026-33634 — LiteLLM PyPI Supply Chain Attack (TeamPCP)
// Platform: CrowdStrike Falcon NG-SIEM / LogScale (CQL — CrowdStrike Query Language)
//           + CrowdStrike Custom IOA (Indicator of Attack) Rules
// MITRE ATT&CK: T1195.001, T1546.018, T1543.002, T1036.004, T1071.004, T1059.006
// Severity: Critical
// Response: Isolate host, revoke credentials, audit pip history
//
// ─── CQL LANGUAGE NOTES ──────────────────────────────────────────────────
//   - Pipe-based: event_simpleName=X field=value | transform | aggregate
//   - Process ID join: TargetProcessId_decimal (ProcessRollup2)
//                  ⟷ ContextProcessId_decimal (DnsRequest / NetworkConnect)
//   - Case-sensitive by default; /pattern/i for case-insensitive regex
//   - Key output functions: table(), groupBy(), count(), sort()
// ─────────────────────────────────────────────────────────────────────────


// ═══════════════════════════════════════════════════════════════════════════
// SECTION A — CQL HUNTING QUERIES (Falcon NG-SIEM / LogScale)
// ═══════════════════════════════════════════════════════════════════════════

// ─── CQL-1: TeamPCP Package Installation + Artifact Drop (Combined) ──────
//
// Detects the first two stages of the attack chain in one query:
//   Stage 1 — pip install of malicious litellm 1.82.7 or 1.82.8
//   Stage 2 — any TeamPCP artifact file created (litellm_init.pth, sysmon.py,
//             sysmon.service, /tmp/pglog, /tmp/.pg_state)
// Combining installation and artifact creation into one query reduces alert volume
// while maintaining full chain coverage. Either condition alone is high-confidence.
//
// MITRE: T1195.001, T1546.018 | Severity: Critical | Response: Isolate

(event_simpleName=ProcessRollup2 CommandLine=/pip(\d)?\s+install\s+.*litellm==
(1\.82\.7|1\.82\.8)/i)
OR
(event_simpleName=FileCreatedEvent
  FileName=/site-
packages\/litellm_init\.pth$|\.config\/sysmon\/sysmon\.py$|\.config\/systemd\/user\/sysmon\.serv
ice$|\/tmp\/(pglog|\.pg_state)$/)
| groupBy([ComputerName, UserName, event_simpleName])
| table(ComputerName, UserName, event_simpleName, CommandLine, FileName, ImageFileName,
timestamp)


// ─── CQL-2: DNS C2 Beacon + Network Connection to TeamPCP Infrastructure ──
//
// Detects outbound communication to all known TeamPCP C2 infrastructure in one query:
```

```
//   DNS queries to: models.litellm.cloud, checkmarx.zone (any subdomain)
//   IP connections to: 45.148.10.212, 83.142.209.11
// Joined to the parent process to provide execution context. Any match is a
// confirmed C2 contact and warrants immediate host isolation.
//
// MITRE: T1071.004, T1071.001 | Severity: Critical | Response: Isolate + block

(event_simpleName=DnsRequest (DomainName="models.litellm.cloud" OR DomainName="checkmarx.zone"
OR DomainName=/\.litellm\.cloud$/))
OR
(event_simpleName=NetworkConnect (RemoteAddressIP4="45.148.10.212" OR
RemoteAddressIP4="83.142.209.11"))
| join ContextProcessId_decimal=TargetProcessId_decimal [event_simpleName=ProcessRollup2]
| table(ComputerName, UserName, event_simpleName, DomainName, RemoteAddressIP4, RemotePort,
ImageFileName, CommandLine, aid, timestamp)


// ─── CQL-3: Full Kill Chain Correlation (pip → Artifact → C2) ───────────────
//
// High-confidence correlation of the complete TeamPCP attack sequence on a single
// host within a rolling window. Joins pip install events to subsequent C2 DNS
// queries from the same process tree. This multi-hop join eliminates nearly all
// false positives and confirms end-to-end compromise with one query.
//
// MITRE: T1195.001 + T1546.018 + T1071.004 | Severity: Critical | Response: IR

event_simpleName=ProcessRollup2 CommandLine=/pip(\d)?\s+install\s+.*litellm/i
| join TargetProcessId_decimal=ContextProcessId_decimal [
    event_simpleName=DnsRequest
    (DomainName="models.litellm.cloud" OR DomainName="checkmarx.zone")
  ]
| table(ComputerName, UserName, CommandLine, DomainName, ImageFileName, aid, timestamp)


// ─── CQL-4: Python Spawning Suspicious Child Processes (Post-Install Hook) ───
//
// Detects Python interpreter spawning shell utilities (bash, curl, wget, sh)
// as direct children — the behavioral signature of TeamPCP's post-install hook
// in setup.py executing its first-stage dropper. Aggregates by host to surface
// hosts with repeated anomalous subprocess patterns.
//
// MITRE: T1059.006 | Severity: High | Response: Inspect CommandLine chain

event_simpleName=ProcessRollup2
ParentImageFilename=/\/(python(\d+(\.\d+)?)?|pip(\d)?)$/i
ImageFileName=/\/(bash|sh|curl|wget|python(\d+(\.\d+)?)?)$/i
| groupBy([ComputerName, UserName, ImageFileName, CommandLine])
| count()
| sort(_count, order=desc)
| where _count ≥ 1


// ═══════════════════════════════════════════════════════════════════════════
// SECTION B — CUSTOM IOA RULES (Indicator of Attack — Behavioral Prevention)
// ═══════════════════════════════════════════════════════════════════════════
//
```

```
// Custom IOA rules run on the Falcon sensor in real time — before the OS executes
// the action. They can BLOCK or ALERT at the kernel level, not just hunt in logs.
// Deploy via: Falcon UI → Detection → Custom IOA → Create Rule Group
// Or via FalconPy API: CustomIOA service (see falconpy.io)
//
// IOA Rule JSON format (for API import):
//   ruletype_id values: 1=Process, 2=File, 3=Network, 4=Registry, 5=DNS
//   pattern_severity: critical, high, medium, low, informational
//   disposition_id: 10=Monitor, 20=Detect, 30=Kill Process

// ── IOA-1: Malicious litellm PyPI Version Installation ────────────────────
//
// Blocks/detects pip commands installing the known-malicious litellm versions.
// Triggers at process creation before the package is downloaded, preventing
// Stage 1 of the TeamPCP attack chain entirely in blocking mode.
//
// MITRE: T1195.001 | Severity: Critical | Recommended disposition: Detect (20)
//
// {
//   "name": "TeamPCP - Malicious litellm Install",
//   "description": "Detects pip install of litellm 1.82.7 or 1.82.8 (CVE-2026-33634 TeamPCP
supply chain attack). Either version contains the litellm_init.pth backdoor payload.",
//   "comment": "CVE-2026-33634 | MITRE T1195.001",
//   "pattern_severity": "critical",
//   "ruletype_id": "1",
//   "disposition_id": 20,
//   "enabled": true,
//   "field_values": [
//     {"name": "CommandLine", "type": "regex",
//      "value": "pip[23]?\\s+install\\s+.*litellm==(1\\.82\\.7|1\\.82\\.8)"},
//     {"name": "ImageFileName", "type": "regex",
//      "value": "/(pip[23]?|python[23]?(\\.[0-9]+)?)$"}
//   ],
//   "platform": "linux"
// }

// ── IOA-2: .pth Hook File Written to site-packages ────────────────────────
//
// Detects any file write creating a .pth file inside a Python site-packages
// directory. Legitimate packages do not dynamically create .pth files at runtime;
// this pattern is almost exclusively used for persistence or code injection via
// Python path interception (T1546.018).
//
// MITRE: T1546.018 | Severity: Critical | Recommended disposition: Detect (20)
//
// {
//   "name": "TeamPCP - Python .pth Hook in site-packages",
//   "description": "Detects creation of any .pth file inside Python site-packages at runtime.
TeamPCP uses litellm_init.pth as a persistent code execution hook that runs on every Python
interpreter startup. No legitimate package creates .pth files dynamically post-install.",
//   "comment": "CVE-2026-33634 | MITRE T1546.018",
//   "pattern_severity": "critical",
//   "ruletype_id": "2",
//   "disposition_id": 20,
//   "enabled": true,
//   "field_values": [
```

```
//     {"name": "TargetFilename", "type": "regex",
//      "value": "site-packages/[^/]+\\.pth$"}
//   ],
//   "platform": "linux"
// }

// ─── IOA-3: Backdoor Persistence — Masquerading systemd Unit ────────────────
//
// Detects creation of files at ~/.config/systemd/user/ or ~/.config/sysmon/
// by non-standard processes (not systemctl, not package managers). TeamPCP drops
// sysmon.service and sysmon.py at these paths to masquerade as legitimate tooling
// and achieve user-level persistence without requiring root privileges.
//
// MITRE: T1543.002, T1036.004 | Severity: High | Recommended disposition: Detect (20)
//
// {
//   "name": "TeamPCP - Hidden Config Backdoor Persistence",
//   "description": "Detects file creation at ~/.config/sysmon/ or ~/.config/systemd/user/ by
processes other than expected system managers. TeamPCP uses sysmon.py (masquerading as
Sysinternals Sysmon) and a systemd user service to maintain persistence across reboots without
root access.",
//   "comment": "CVE-2026-33634 | MITRE T1543.002, T1036.004",
//   "pattern_severity": "high",
//   "ruletype_id": "2",
//   "disposition_id": 20,
//   "enabled": true,
//   "field_values": [
//     {"name": "TargetFilename", "type": "regex",
//      "value": "\\.config/(sysmon/|systemd/user/).*\\.(py|service)$"},
//     {"name": "ImageFileName", "type": "regex",
//      "value": "/(pip[23]?|python[23]?(\\.[0-9]+)?|curl|wget|bash|sh)$"}
//   ],
//   "platform": "linux"
// }

// ─── IOA-4: DNS Query to TeamPCP C2 Typosquat Domains ────────────────────────
//
// Detects DNS resolution attempts for TeamPCP command-and-control domains.
// models.litellm.cloud impersonates litellm.ai; checkmarx.zone impersonates the
// Checkmarx security vendor. This IOA fires at the DNS layer before any network
// data is exfiltrated, enabling early-stage C2 disruption.
//
// MITRE: T1071.004 | Severity: Critical | Recommended disposition: Detect (20)
//
// {
//   "name": "TeamPCP - C2 DNS Resolution Attempt",
//   "description": "Detects DNS queries to TeamPCP C2 infrastructure: models.litellm.cloud
(typosquat of litellm.ai) and checkmarx.zone (typosquat of checkmarx.com). Any DNS resolution of
these domains from an endpoint indicates active TeamPCP backdoor beacon activity.",
//   "comment": "CVE-2026-33634 | MITRE T1071.004",
//   "pattern_severity": "critical",
//   "ruletype_id": "5",
//   "disposition_id": 20,
//   "enabled": true,
//   "field_values": [
//     {"name": "DomainName", "type": "regex",
```

```
//      "value": "(models\\.litellm\\.cloud|checkmarx\\.zone|.*\\.litellm\\.cloud)"}
//   ],
//   "platform": "linux"
// }
```

5 Red Team Simulation

Purpose: Validate detection rules in an isolated lab environment before relying on them in production. All steps are safe simulations â€" no real exploits or working payloads. Prerequisites: Isolated lab VM, Python + pip installed, EDR agent running and sending telemetry, VM snapshot taken.

1. **Simulate pip install (dry-run):** Run `pip install litellm==1.82.7 --dry-run`. Verify process creation rules fire on CommandLine containing litellm==1.82.7.
2. **Create .pth artifact:** `mkdir -p /tmp/site-packages && touch /tmp/site-packages/litellm_init.pth`. Verify file creation rules fire.
3. **Create backdoor artifact:** `mkdir -p ~/.config/sysmon && touch ~/.config/sysmon/sysmon.py`. Verify rules fire on sysmon.py in hidden config path.
4. **Simulate systemd persistence:** `mkdir -p ~/.config/systemd/user && touch ~/.config/systemd/user/sysmon.service`. Verify T1543.002 rules fire.
5. **Simulate DNS C2 lookup:** `nslookup models.litellm.cloud.local.test 2>/dev/null || true`. Verify DNS rules fire on models.litellm.cloud pattern.

Detection Validation Checklist

PLATFORM	RULE	EXPECTED ALERT	TRIGGERED?
Sigma	TeamPCP Malicious Install	Process event with litellm==1.82.7 in CommandLine	â˜
KQL	File Artifacts Detection	DeviceFileEvents TargetFilename match	â˜
Splunk	C2 Indicators Combined	Sysmon EventCode=22 OR 3 C2 match	â˜
CrowdStrike	CQL-2 DNS C2 Beacon	DnsRequest DomainName = models.litellm.cloud	â˜
SentinelOne	File Artifacts & Persistence	File Creation TgtFile.Path sysmon.service	â˜
YARA	TeamPCP PTH Hook File	Static scan match on .pth payload strings	â˜

6 References

FutureSearch	https://futuresearch.ai/blog/litellm-pypi-supply-chain-attack/
Sysdig	https://sysdig.com/blog/teampcp-pypi-supply-chain/
Datadog Security	https://securitylabs.datadoghq.com/articles/litellm-compromised-pypi-teampcp-supply-chain-campaign/
Snyk	https://snyk.io/articles/poisoned-security-scanner-backdooring-litellm/
Kaspersky	https://www.kaspersky.com/blog/critical-supply-chain-attack-trivy-litellm-checkmarx-teampcp/55510/
ReversingLabs	https://github.com/reversinglabs/reversinglabs-yara-rules
ARMO	https://www.armosec.io/blog/teampcp-kubernetes-attack/
Sonatype	https://www.sonatype.com/blog/litellm-pypi-supply-chain
Wiz	https://www.wiz.io/blog/threes-a-crowd-teampcp-trojanizes-litellm-in-continuation-of-campaign/
NVD	https://nvd.nist.gov/vuln/detail/CVE-2026-33634